

Weekly IT Security Brief (Official-source-first) | 2026-03-16 15:06

Formatted for readability • Auto-generated

Weekly Summary (TL;DR)

- Priority snapshot: 3 KEV-listed vulnerabilities are actively exploited in the wild (top 8 shown in this brief).
- Urgent patch focus: CVE-2026-3910(2026-03-27), CVE-2026-3909(2026-03-27), CVE-2025-68613(2026-03-25). Prioritize internet-facing and privileged systems first.
- Threat trend #1: Storm-2561 uses SEO poisoning to distribute fake VPN clients for credential theft. Storm-2561 uses SEO poisoning to distribute fake VPN clients for credential theft | Microsoft Security Blog Skip to content Skip to main content Microsoft Microsoft Security Microsoft Security Microsoft Security Home Why Microsoft Security Solutions AI-powered cybersecurity Cloud security Data security Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
- Threat trend #2: From transparency to action: What the latest Microsoft email security benchmark reveals. From transparency to action: What the latest Microsoft email security benchmark reveals | Microsoft Security Blog Skip to content Skip to main content Microsoft Microsoft Security Microsoft Security Microsoft Security Home Why Microsoft Security Solutions AI-powered cybersecurity Cloud security Data security Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
- Recommended action this week: patch KEV/high-risk exposed services within 24 hours and tighten monitoring for anomalous login, command execution, and credential access patterns.

Report A: CVE Deep Dive (CISA KEV + NVD)

1. CVE-2026-3910

- CVE Title: CVE-2026-3910 | google/chrome | Unknown Type
- CVE Description: Inappropriate implementation in V8 in Google Chrome prior to 146.0.7680.75 allowed a remote attacker to execute arbitrary code inside a sandbox via a crafted HTML page. (Chromium security severity: High)
 - Root Cause: Use vendor advisories and patch notes for authoritative technical details.
 - Exploitation Prerequisite: Affected version is reachable through an exploitable path and remains unpatched.
 - Exploit Path: Attacker leverages public PoC or observed exploit chain for intrusion.
 - Affected Products: google/chrome, apple/macos, linux/linux_kernel, microsoft/windows
 - Risk Score: 8.8 (HIGH)
 - Exploited in the wild: Listed in CISA KEV
 - KEV remediation due date: 2026-03-27
 - Mitigation: Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
- Source: <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>
- Source: <https://nvd.nist.gov/vuln/detail/CVE-2026-3910>

2. CVE-2026-3909

- CVE Title: CVE-2026-3909 | google/chrome | Unknown Type
- CVE Description: Out of bounds write in Skia in Google Chrome prior to 146.0.7680.75 allowed a remote attacker to perform out of bounds memory access via a crafted HTML page. (Chromium security severity: High)
- Root Cause: Use vendor advisories and patch notes for authoritative technical details.
- Exploitation Prerequisite: Affected version is reachable through an exploitable path and remains unpatched.
- Exploit Path: Attacker leverages public PoC or observed exploit chain for intrusion.
- Affected Products: google/chrome, apple/macOS, linux/linux_kernel, microsoft/windows
- Risk Score: 8.8 (HIGH)
- Exploited in the wild: Listed in CISA KEV
- KEV remediation due date: 2026-03-27
- Mitigation: Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
- Source: <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>
- Source: <https://nvd.nist.gov/vuln/detail/CVE-2026-3909>

3. CVE-2025-68613

- CVE Title: CVE-2025-68613 | n8n/n8n | Remote Code Execution
 - CVE Description: n8n is an open source workflow automation platform. Versions starting with 0.211.0 and prior to 1.120.4, 1.121.1, and 1.122.0 contain a critical Remote Code Execution (RCE) vulnerability in their workflow expression evaluation system. Under certain conditions, expressions supplied by authenticated users during workflow configuration may be evaluated in an execution context that is not sufficiently isolated from the underlying runtime. An authenticated attacker could abuse this behavior to execute arbitrary code with the privileges of the n8n process. Successful exploitation may lead to full compromise of the affected instance, including unauthorized access to sensitive data, modification of
 - Root Cause: Unsafe deserialization or input-handling flaws enable arbitrary code execution.
 - Exploitation Prerequisite: Relevant endpoint is exposed and unpatched.
 - Exploit Path: Malicious request/payload -> vulnerability trigger -> remote command execution.
 - Affected Products: n8n/n8n
 - Risk Score: 9.9 (CRITICAL)
 - Exploited in the wild: Listed in CISA KEV
 - KEV remediation due date: 2026-03-25
 - Mitigation: Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
 - Source: <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>
 - Source: <https://nvd.nist.gov/vuln/detail/CVE-2025-68613>
-

 Report A2: Newly Published CVEs (NVD, last 7 days)

1. CVE-2026-3807

- CVE Title: CVE-2026-3807 | tenda/fh1202_firmware | Buffer Overflow
- CVE Description: A security vulnerability has been detected in Tenda FH1202 1.2.0.14(408). Impacted is the function formWrlsafeset of the file /goform/AdvSetWrlsafeset. Such manipulation of the argument mit_ssid/mit_ssid_index leads to stack-based buffer overflow. The attack can be launched remotely. The exploit has been disclosed publicly and may be used.
- Affected Products: tenda/fh1202_firmware, tenda/fh1202
- Risk Score: 8.8 (HIGH)

- Source: <https://nvd.nist.gov/vuln/detail/CVE-2026-3807>

2. CVE-2026-3823

- CVE Title: CVE-2026-3823 | blackbeartechhive/atop_ehg2408_firmware | Buffer Overflow

- CVE Description: EHG2408 series switch developed by Atop Technologies has a Stack-based Buffer Overflow vulnerability, allowing unauthenticated remote attackers to control the program's execution flow and execute arbitrary code.

- Affected Products: blackbeartechhive/atop_ehg2408_firmware, blackbeartechhive/atop_ehg2408, blackbeartechhive/atop_ehg2408-2sfp_firmware, blackbeartechhive/atop_ehg2408-2sfp

- Risk Score: 8.8 (HIGH)

- Source: <https://nvd.nist.gov/vuln/detail/CVE-2026-3823>

3. CVE-2026-3808

- CVE Title: CVE-2026-3808 | tenda/fh1202_firmware | Buffer Overflow

- CVE Description: A vulnerability was detected in Tenda FH1202 1.2.0.14(408). The affected element is the function formWebTypeLibrary of the file /goform/webtypelibrary. Performing a manipulation of the argument webSiteId results in stack-based buffer overflow. The attack may be initiated remotely. The exploit is now public and may be used.

- Affected Products: tenda/fh1202_firmware, tenda/fh1202

- Risk Score: 8.8 (HIGH)

- Source: <https://nvd.nist.gov/vuln/detail/CVE-2026-3808>

4. CVE-2026-3809

- CVE Title: CVE-2026-3809 | tenda/fh1202_firmware | Buffer Overflow

- CVE Description: A flaw has been found in Tenda FH1202 1.2.0.14(408). The impacted element is the function fromNatStaticSetting of the file /goform/NatSaticSetting. Executing a manipulation of the argument page can lead to stack-based buffer overflow. The attack may be launched remotely. The exploit has been published and may be used.

- Affected Products: tenda/fh1202_firmware, tenda/fh1202

- Risk Score: 8.8 (HIGH)

- Source: <https://nvd.nist.gov/vuln/detail/CVE-2026-3809>

5. CVE-2026-3810

- CVE Title: CVE-2026-3810 | tenda/fh1202_firmware | Buffer Overflow

- CVE Description: A vulnerability has been found in Tenda FH1202 1.2.0.14(408). This affects the function fromDhcpListClient of the file /goform/DhcpListClient. The manipulation of the argument page leads to stack-based buffer overflow. Remote exploitation of the attack is possible. The exploit has been disclosed to the public and may be used.

- Affected Products: tenda/fh1202_firmware, tenda/fh1202

- Risk Score: 8.8 (HIGH)

- Source: <https://nvd.nist.gov/vuln/detail/CVE-2026-3810>

6. CVE-2025-41754

- CVE Title: CVE-2025-41754 | mbs-solutions/universal_bacnet_router_firmware | Unknown Type

- CVE Description: A low-privileged remote attacker can exploit the ubr-editfile method in wwwubr.cgi, an undocumented and unused API endpoint to read arbitrary files on the system.

- Affected Products: mbs-solutions/universal_bacnet_router_firmware, mbs-solutions/ubr-01_mk_ii, mbs-solutions/ubr-02, mbs-solutions/ubr-lon

- Risk Score: 6.5 (MEDIUM)

- Source: <https://nvd.nist.gov/vuln/detail/CVE-2025-41754>

1. Headline: Storm-2561 uses SEO poisoning to distribute fake VPN clients for credential theft

- Source: Microsoft Security Blog

- Published: Thu, 12 Mar 2026 17:00:00 +0000

- Key Takeaway: Storm-2561 uses SEO poisoning to distribute fake VPN clients for credential theft | Microsoft Security Blog Skip to content Skip to main content Microsoft Microsoft Security Microsoft Security Microsoft Security Home Why Microsoft Security Solutions AI-powered cybersecurity Cloud security Data secur Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.

- Summary Engine: extractive-rules

- Threat Actors: Not explicitly stated

- Target: ics/待核實

- Technique: Credential Access

- MITRE ATT&CK: Unverified

- Related CVEs: None

- Link: <https://www.microsoft.com/en-us/security/blog/2026/03/12/storm-2561-uses-seo-poisoning-to-distribute-fake-vpn-clients-for-credential-theft/>

2. Headline: From transparency to action: What the latest Microsoft email security benchmark reveals

- Source: Microsoft Security Blog

- Published: Thu, 12 Mar 2026 16:00:00 +0000

- Key Takeaway: From transparency to action: What the latest Microsoft email security benchmark reveals | Microsoft Security Blog Skip to content Skip to main content Microsoft Microsoft Security Microsoft Security Microsoft Security Home Why Microsoft Security Solutions AI-powered cybersecurity Cloud security Data Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.

- Summary Engine: extractive-rules

- Threat Actors: Not explicitly stated

- Target: technology/待核實

- Technique: 待核實

- MITRE ATT&CK: Unverified

- Related CVEs: None

- Link: <https://www.microsoft.com/en-us/security/blog/2026/03/12/from-transparency-to-action-what-the-latest-microsoft-email-security-benchmark-reveals/>

3. Headline: CISA Issues Updated RESURGE Malware Analysis Highlighting a Stealthy but Active Threat

- Source: CISA News

- Published: Thu, 26 Feb 2026 12:00:00 +0000

- Key Takeaway: CISA Issues Updated RESURGE Malware Analysis Highlighting a Stealthy but Active Threat | CISA Skip to main content An official website of the United States government Here's how you know Here's how you know Official websites use .gov A .gov website belongs to an official government organization in t Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.

- Summary Engine: extractive-rules

- Threat Actors: Not explicitly stated

- Target: unknown-target

- Technique: Malware Deployment

- MITRE ATT&CK: Unverified

- Related CVEs: None

- Link: <https://www.cisa.gov/news-events/news/cisa-issues-updated-resurge-malware-analysis-highlighting-stealthy-active-threat>

4. Headline: Immediate Action Required: CISA Issues Emergency Directive to Secure Cisco SD-WAN

Systems

- Source: CISA News
- Published: Wed, 25 Feb 26 12:00:00 +0000
- Key Takeaway: Immediate Action Required: CISA Issues Emergency Directive to Secure Cisco SD-WAN

Systems | CISA Skip to main content An official website of the United States government Here's how you know Here's how you know Official websites use .gov A .gov website belongs to an official government organization i Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.

- Summary Engine: extractive-rules
- Threat Actors: Not explicitly stated
- Target: unknown-target
- Technique: 待核實
- MITRE ATT&CK: Unverified
- Related CVEs: None
- Link: [https://www.cisa.gov/news-events/news/immediate-action-required-cisa-issues-emergency-](https://www.cisa.gov/news-events/news/immediate-action-required-cisa-issues-emergency-directive-secure-cisco-sd-wan-systems)

directive-secure-cisco-sd-wan-systems

5. Headline: Proactive Preparation and Hardening Against Destructive Attacks: 2026 Edition

- Source: Mandiant Blog
- Published: Fri, 06 Mar 2026 14:00:00 +0000
- Key Takeaway: Destructive cyberattacks can include destructive malware, wipers, or modified

ransomware. Pre-Establish Trusted Third-Party Vendor Relationships: Based on the range of technologies and platforms vital to business operations, develop predefined agreements with external partners to ensure access to sp Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.

- Summary Engine: extractive-rules
- Threat Actors: Not explicitly stated
- Target: defense/global
- Technique: T1003.002,T1003.006,T1021.001
- MITRE ATT&CK: T1003.002, T1003.006, T1021.001, T1021.002, T1021.003, T1021.004, T1021.006, T1021.007, T1046, T1047, T1049, T1059.004, T1068, T1069, T1072, T1078, T1078.003, T1078.004, T1098, T1098.001, T1098.005, T1105, T1110, T1110.003, T1112, T1135, T1187, T1195.002, T1212, T1219, T1484.001, T1485, T1486, T1490, T1525, T1529, T1550.001, T1552.007, T1556, T1556.009, T1557, T1557.001, T1558.003, T1558.004, T1562.001, T1562.007, T1562.008, T1569.002, T1570, T1578.005, T1611, T1621, T1649, T1654

- Related CVEs: None
- Link: [https://cloud.google.com/blog/topics/threat-intelligence/preparation-hardening-destructive-](https://cloud.google.com/blog/topics/threat-intelligence/preparation-hardening-destructive-attacks/)

attacks/

6. Headline: Look What You Made Us Patch: 2025 Zero-Days in Review

- Source: Mandiant Blog
- Published: Thu, 05 Mar 2026 14:00:00 +0000
- Key Takeaway: Written by: Casey Charrier, James Sadowski, Zander Work, Clement Lecigne, Benoît

Sevens, Fred Plan Executive Summary Google Threat Intelligence Group (GTIG) tracked 90 zero-day vulnerabilities exploited in-the-wild in 2025. In 2025, we continued to observe the structural shift, first identified in 2 Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.

- Summary Engine: extractive-rules
- Threat Actors: CIOp
- Target: defense/待核實
- Technique: Phishing
- MITRE ATT&CK: Unverified

- Related CVEs: CVE-2021-37973, CVE-2023-2136, CVE-2023-33106, CVE-2023-6345, CVE-2024-0519, CVE-2025-0282, CVE-2025-14174, CVE-2025-21042, CVE-2025-21043, CVE-2025-21590, CVE-2025-23006, CVE-2025-27038, CVE-2025-2783, CVE-2025-38352, CVE-2025-40602, CVE-2025-43300, CVE-2025-48543, CVE-2025-5419, CVE-2025-61882, CVE-2025-61884, CVE-2025-6558, CVE-2025-8088

- Link: <https://cloud.google.com/blog/topics/threat-intelligence/2025-zero-day-review/>

7. Headline: This one's for you, Mom

- Source: Cisco Talos Blog

- Published: Thu, 12 Mar 2026 18:00:01 GMT

- Key Takeaway: This one's for you, Mom Blog Intelligence Center Intelligence Center BACK Intelligence Search Email & Spam Trends Vulnerability Research Vulnerability Research BACK Vulnerability Reports Microsoft Advisories Incident Response Incident Response BACK Reactive Services Proactive Services Emergency Supp Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.

- Summary Engine: extractive-rules

- Threat Actors: Not explicitly stated

- Target: unknown-target

- Technique: 待核實

- MITRE ATT&CK: Unverified

- Related CVEs: None

- Link: <https://blog.talosintelligence.com/this-ones-for-you-mom/>

8. Headline: DirectX, OpenFOAM, Libbiosig vulnerabilities

- Source: Cisco Talos Blog

- Published: Wed, 11 Mar 2026 20:26:57 GMT

- Key Takeaway: Cisco Talos' Vulnerability Discovery & Research team recently disclosed vulnerabilities in the BioSig Project Libbiosig library and OpenCFD OpenFOAM, as well as an unpatched vulnerability in Microsoft DirectX. The vulnerabilities mentioned in this blog post have been patched by their respective vendors. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.

- Summary Engine: extractive-rules

- Threat Actors: Not explicitly stated

- Target: ios/待核實

- Technique: 待核實

- MITRE ATT&CK: Unverified

- Related CVEs: None

- Link: <https://blog.talosintelligence.com/directx-openfoam-libbiosig-vulnerabilities/>

9. Headline: Android 17 Blocks Non-Accessibility Apps from Accessibility API to Prevent Malware Abuse

- Source: The Hacker News

- Published: Mon, 16 Mar 2026 11:13:00 +0530

- Key Takeaway: Google is testing a new security feature as part of Android Advanced Protection Mode (AAPM) that prevents certain kinds of apps from using the accessibility services API. The change, incorporated in Android 17 Beta 2, was first reported by Android Authority last week. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.

- Summary Engine: extractive-rules

- Threat Actors: Not explicitly stated

- Target: ot/待核實

- Technique: Malware Deployment

- MITRE ATT&CK: Unverified

- Related CVEs: None

- Link: <https://thehackernews.com/2026/03/android-17-blocks-non-accessibility.html>

10. **Headline:** OpenClaw AI Agent Flaws Could Enable Prompt Injection and Data Exfiltration

- Source: The Hacker News

- Published: Sat, 14 Mar 2026 21:47:00 +0530

- Key Takeaway: China's National Computer Network Emergency Response Technical Team (CNCERT) has issued a warning about the security stemming from the use of OpenClaw (formerly Clawdbot and Moltbot), an open-source and self-hosted autonomous artificial intelligence (AI) agent. In a post shared on WeChat, CNCERT not Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.

- Summary Engine: extractive-rules

- Threat Actors: Not explicitly stated

- Target: ot/待核實

- Technique: 待核實

- MITRE ATT&CK: Unverified

- Related CVEs: None

- Link: <https://thehackernews.com/2026/03/openclaw-ai-agent-flaws-could-enable.html>

11. **Headline:** Loblaw Data Breach Impacts Customer Information

- Source: SecurityWeek

- Published: Sun, 15 Mar 2026 10:00:00 +0000

- Key Takeaway: The post Loblaw Data Breach Impacts Customer Information appeared first on SecurityWeek . Loblaw Data Breach Impacts Customer Information - SecurityWeek SECURITYWEEK NETWORK: Cybersecurity News Webcasts Virtual Events ICS: ICS Cybersecurity Conference Malware & Threats Cyberwarfare Cybercrime Data B Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.

- Summary Engine: extractive-rules

- Threat Actors: Not explicitly stated

- Target: unknown-target

- Technique: 待核實

- MITRE ATT&CK: Unverified

- Related CVEs: None

- Link: <https://www.securityweek.com/loblaw-data-breach-impacts-customer-information/>

12. **Headline:** Critical HPE AOS-CX Vulnerability Allows Admin Password Resets

- Source: SecurityWeek

- Published: Sat, 14 Mar 2026 10:50:00 +0000

- Key Takeaway: The vulnerability can be exploited remotely, without authentication, to circumvent existing authentication controls. The post Critical HPE AOS-CX Vulnerability Allows Admin Password Resets appeared first on SecurityWeek . Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.

- Summary Engine: extractive-rules

- Threat Actors: Not explicitly stated

- Target: ot/待核實

- Technique: Exploit Chain

- MITRE ATT&CK: Unverified

- Related CVEs: None

- Link: <https://www.securityweek.com/critical-hpe-aos-cx-vulnerability-allows-admin-password-resets/>

- <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>
- <https://nvd.nist.gov/>
- <https://www.cve.org/>
- <https://attack.mitre.org/>
- <https://www.microsoft.com/en-us/security/blog/>
- <https://www.cisa.gov/news-events/cybersecurity-advisories>
- <https://www.mandiant.com/resources>
- <https://blog.talosintelligence.com/>